

CruDoc Security Implementation Plan

Date	10 October 2026
Status	Draft for approval
Goal	Bank-grade protection for patient data, proven by an external security test (VAPT) and ISO 27001 certification
Scope	The whole CruDoc platform: mobile, web and Windows apps, Firebase backend, AI features, AI receptionist (Sarvam), WhatsApp (Meta), super admin
Legal frame	India: DPDP Act 2023 + Rules 2025 (main duties from about May 2027), IT Act SPDI Rules, CERT-In Directions 2022, NMC/DCI record retention
Related	<code>docs/ai_receptionist_plan.md</code> (voice/WhatsApp tasks V1–V12 are part of this plan's Phase 0)

0. Summary in plain words

What "heavy security" means for CruDoc

Six layers. An attacker would have to break several of them, not just one.

#	Layer	In one line	Today
1	Encryption in transit	Every connection is encrypted (TLS)	✓
2	Encryption at rest (Google)	Google encrypts all stored data with AES-256	✓
3	Patient-level encryption, keys in a hardware vault	Patient details are encrypted per clinic; the master key sits in a certified hardware security module (Cloud HSM) in India and can never be copied out	⚠ Encryption exists, keys are weak
4	Device encryption + app lock	Data on phones and PCs is encrypted; the app locks itself when idle	⚠ Windows unencrypted, no app lock
5	Locked-down access	Two-factor login, only genuine CruDoc apps can talk to the server, every patient record access recorded, alerts on anything unusual	⚠ Partly
6	Proof from outside	VAPT by a CERT-In empanelled auditor, then ISO 27001 certification	✗

The 7 biggest gaps today

- Patient-data keys can be recreated by anyone holding the app file.** The key that protects each clinic's data key is `SHA-256(clinicId + a constant inside the app)` (`lib/core/services/encryption_key_manager.dart:23, :88`). Copy the app plus a database dump, and every patient can be decrypted.
- No two-factor login** for doctors, staff or admins (`lib/core/services/auth_service.dart`: Google, phone OTP, email/password only).
- No App Check.** Any script with the public Firebase config can call our backend as if it were the app.
- The Windows desktop database is unencrypted** (`lib/core/services/local_database_service.dart, WindowsDatabase`, documented as an intentional gap).
- Patient data goes to Google's public Gemini API** (`functions/src/ai.ts:18, lib/core/services/gemini_json_client.dart:180, voice_transcription_service.dart:184`) instead of Vertex AI in India.
- Weak spots in the voice and WhatsApp code** (details in the AI receptionist plan, §2):
 - Reminders read encrypted fields and could message random numbers.

- Legacy voice endpoints trust any `doctor_id`.
- Patient names and phones are written to the logs.

7. **No external verification yet:** no VAPT, no ISO 27001, no written incident-response plan.

Timeline and cost at a glance

Phase	When	What	Rough cost
0. Launch-critical	Now → 31 Oct 2026	Fix voice/WhatsApp risks, protect admin accounts, backups, budget alerts	~₹0
1. Keys & data	1–15 Nov	Hardware-vault keys + migration, Gemini → Vertex AI India, scrub logs	< ₹1,000/month
2. Access & devices	15 Nov – 10 Dec	Two-factor login, app lock, App Check, Windows encryption, full audit trail	~₹0–500/month
3. Monitoring & response	1–20 Dec	180-day logs in India, alerts, incident plan, DPDP features, hardening	Small
4. VAPT	10 Dec – 15 Jan 2027	External test by a CERT-In empanelled auditor, fix findings	₹50k–2 lakh
5. ISO 27001	Jan – Jun 2027	Policies, risk assessment, internal audit, certification audit	₹3–8 lakh (year 1)

Total coding effort: about **25–30 working days**, spread over Phases 0–3.

Honest note: no system is unhackable. Most real breaches come from stolen passwords, phishing and leaked admin accounts, not broken encryption. That's why two-factor login and protecting **your own** admin accounts (Google Cloud, Firebase, Meta, Sarvam, GitHub) are in Phase 0, before anything else.

1. Where we stand today

Area	Control	Status	Evidence
Transport	TLS on all Firebase / Meta / Sarvam traffic	✓	Platform default
Storage	Google encryption at rest (AES-256)	✓	Platform default
Patient fields	AES-256-GCM per clinic on name, phone, diagnosis, notes, address	✓	<code>field_cipher.dart</code> , <code>patient_repository.dart:44</code> , <code>visits_repo.dart:75</code>
Key protection	Clinic key wrapped by <code>SHA-256(clinicId::pepper)</code> , pepper in the app	✗ weak	<code>encryption_key_manager.dart:23</code> , <code>:88</code>
Mobile local DB	SQLCipher with a passphrase in secure storage	✓	<code>local_database_service.dart:139</code>
Windows local DB	Unencrypted SQLite	✗	<code>local_database_service.dart</code> (<code>WindowsDatabase</code>)
Login	Google, phone OTP, email/password	⚠ no 2FA	<code>auth_service.dart</code> , <code>auth_screen.dart:535</code>
App Check	None	✗	no <code>firebase_app_check</code> in <code>pubspec.yaml</code>
Roles & permissions	Clinic roles, Firestore rules per permission	✓	<code>functions/src/clinic.ts</code> , <code>firestore.rules</code>

Area	Control	Status	Evidence
Removing staff	Refresh tokens revoked on removal	✓	<code>functions/src/clinic.ts:956</code>
Access audit	<code>access_logs</code> for views/downloads, written by the app	⚠ partial, client-written	<code>access_audit_service.dart</code>
Admin audit	<code>audit_logs</code> for super admin actions	✓	<code>functions/src/super-admin.ts:71</code>
Secrets	Secret Manager for API keys	✓	<code>defineSecret</code> in functions
Secret scanning	CI workflow	✓	<code>.github/workflows/secret_scan.yml</code>
WhatsApp webhook	Signature verified, fails closed	✓	<code>functions/src/whatsapp/webhook.ts</code>
Voice API	Shared API key; trusts <code>doctor_id</code> ; no ownership check on cancel	⚠	<code>functions/src/appointments.ts</code>
AI provider	Gemini developer API (global)	⚠	<code>functions/src/ai.ts:18</code> , <code>gemini_json_client.dart:180</code>
PHI in logs	Patient name + phone logged	✗	<code>appointments.ts:826</code>
Web headers	No CSP / HSTS / frame protection	✗	<code>firebase.json</code> has no <code>headers</code>
Release builds	No obfuscation	⚠	no <code>--obfuscate</code> in <code>release.yml</code>
Backups	Not configured	✗	–
Log retention	Cloud Logging default (30 days)	✗ CERT-In needs 180 days	–
Incident response	No written plan	✗	–
Legacy voice service	<code>voice-receptionist/</code> (Python, Postgres, Redis, Gemini, Sarvam TTS) still in repo	⚠	<code>voice-receptionist/</code>

2. Target design

2.1 Keys and encryption



- Each clinic keeps **one random data key (DEK)**. Only its wrapping changes: from the app constant to **Cloud KMS with HSM protection** (FIPS 140-2 Level 3).
- `doctor_keys` **becomes server-only** in Firestore rules. Clients can no longer even read the wrapped key; they ask `getClinicKey`, which checks membership, App Check and two-factor login.
- The app keeps caching the DEK in secure storage (as today), so **offline use still works**.
- **Design choice:** CruDoc's servers *can* read patient fields, under audit. That's required for reminders and the AI receptionist. Full end-to-end encryption, where even CruDoc's servers can't read the data, would rule out both features.
- **Rotation:** KMS rotates the KEK every 90 days automatically. Old versions stay able to unwrap, and keys are re-wrapped lazily. Clinic DEKs can be rotated per clinic if a device or employee is compromised: decrypt and re-encrypt that clinic's fields with a server job.
- **Phone lookup:** `phoneIndex = HMAC-SHA256(DEK, E.164 phone)`, as in the AI receptionist plan §2.3.

2.2 Who can call the backend

Caller	Proof required
CruDoc mobile app	Firebase Auth + App Check (Play Integrity / App Attest) + 2FA for sensitive actions
CruDoc web app	Firebase Auth + App Check (reCAPTCHA Enterprise) + 2FA
CruDoc Windows app	Firebase Auth + device registration (custom App Check provider, see SEC-21) + 2FA
Sarvam (voice tools, webhooks)	<code>X-API-Key</code> (rotated) + request signing / IP allowlist if Sarvam supports it + server-side line → clinic resolution
Meta (WhatsApp webhook)	HMAC signature with app secret
Super admin app	<code>@svayatta.in</code> email-link auth + 2FA + super-admin claim
Cloud Scheduler	Built-in service identity

3. Workstreams

3.1 Encryption and keys

ID	Task	Details
SEC-10	KMS key ring + HSM key	<code>crudoc-phi</code> in <code>asia-south1</code> (confirm Cloud HSM availability there, else <code>asia-south2</code>), key <code>clinic-dek-wrap</code> , protection level HSM, 90-day rotation. IAM: only the functions' service account gets <code>cryptoKeyEncrypterDecrypter</code> .
SEC-11	Server crypto module	<code>functions/src/crypto/</code> : KMS unwrap/wrap, DEK cache (≤ 5 min, in memory), <code>enc:v1</code> decrypt/encrypt, <code>phoneIndex</code> . Replaces the pepper approach in AI plan task V1.
SEC-12	Callable <code>getClinicKey</code>	Signed-in member of the clinic + App Check + recent 2FA. Returns the DEK over TLS. Writes <code>access_logs</code> (type <code>key_fetch</code>).
SEC-13	Migration	Admin job per clinic: unwrap with the old pepper KEK, re-wrap with KMS, write <code>kmsWrappedKey</code> , keep <code>wrappedKey</code> until all app versions are updated. Then delete <code>wrappedKey</code> , set <code>doctor_keys</code> rules to server-only, and remove the pepper from the app. Force-update the minimum app version before the cut-over.
SEC-14	Encrypt remaining PHI written by the server	AI-created patients and appointment notes are written encrypted (AI plan §2.2). Review every function for plaintext PHI writes.
SEC-15	Storage files	Confirm medical files in Firebase Storage are only reachable through rules or signed URLs with short expiry. Encrypt highly sensitive uploads (e.g. reports) with the clinic DEK before upload if the rules review finds gaps.

3.2 Devices

ID	Task	Details
SEC-20	Windows database encryption	Spike: open SQLite on Windows through SQLCipher (<code>sqlcipher_flutter_libs</code> with the <code>sqlite3</code> override). Migration: finish pending sync → delete the plain cache → recreate encrypted → re-download. Fallback if SQLCipher on Windows is blocked: field-level encryption of PHI columns in the local cache, plus a clinic policy requiring BitLocker.
SEC-21	Windows App Check	There's no built-in App Check provider for Windows. Build a custom provider : the device registers once after 2FA login, gets a device key stored in Windows Credential Manager, and a function issues App Check tokens for registered devices. Lost devices can be revoked from the app.
SEC-22	App lock	Lock after 5 minutes idle (setting: 1–15). Unlock with biometrics / Windows Hello / device PIN (<code>local_auth</code>). Also lock on app switch for PHI screens.
SEC-23	Release hardening	Build with <code>--obfuscate --split-debug-info</code> in <code>release.yml</code> ; strip <code>debugPrint</code> of PHI in release; <code>FLAG_SECURE</code> (no screenshots or recents preview) on patient screens on Android. Optional: root/jailbreak warning.
SEC-24	Sign-out wipe	On sign-out or removal from a clinic: delete the local DB file and the cached DEK (partly exists via <code>deleteCacheFor</code> ; verify every path).

3.3 Identity and access

ID	Task	Details
SEC-30	Two-factor login (MFA)	Upgrade Firebase Auth to Identity Platform , then enable TOTP (authenticator app) as the second factor, with SMS as a fallback. Required for clinic owners and admins; on by default for everyone. Check that MFA works on the Windows build; if not, desktop login goes through a browser sign-in that enforces it.

ID	Task	Details
SEC-31	Step-up for sensitive actions	Re-authenticate (2FA within the last 15 minutes) before: exporting data, bulk downloads, changing roles, connecting WhatsApp, registering an AI phone line, fetching the key on a new device.
SEC-32	Session control	Sessions list per user ("signed in on 3 devices") with "sign out everywhere" (revoke refresh tokens). Already revoked on staff removal  .
SEC-33	App Check	Add <code>firebase_app_check</code> : Play Integrity (Android), App Attest (iOS), reCAPTCHA Enterprise (web), custom (Windows, SEC-21). Run in monitor mode for 2 weeks, then enforce on Firestore, Storage and callables.
SEC-34	Your admin accounts	Hardware security key or passkey + 2FA on every account that can reach patient data or billing: Google Cloud/Firebase owners, GitHub, Meta Business, Sarvam, domain registrar, Gmail. No shared logins. Remove ex-collaborators. Do this first: it's the most likely way in.
SEC-35	Least-privilege cloud access	Separate service accounts per function group (voice, WhatsApp, AI, admin) with only the roles each needs. Nobody uses the Owner role day to day. Review IAM quarterly.
SEC-36	Super admin	2FA enforced, actions already audited  . Add an alert on every super-admin action outside office hours.

3.4 Backend and APIs

ID	Task	Details
SEC-40	Voice API hardening	From the AI receptionist plan: server resolves line → clinic, ownership checks, idempotency, per-caller limits (≤ 5 calls/day per caller per line), 4-minute call cap, minimal information disclosure, "changed by phone" WhatsApp notice.
SEC-41	Remove legacy surface	Delete the exports <code>createAppointment</code> , <code>getAvailability</code> and <code>cancelAppointment</code> once <code>voiceApi</code> is live. Decide on voice-receptionist/ : decommission it (recommended once Sarvam's agent is live) or bring it into the VAPT scope.
SEC-42	CORS	No <code>cors: true</code> on server-to-server endpoints (three today). Web callables only allow CruDoc's own domains.
SEC-43	Rate limiting	Per-user and per-IP limits on callables (Firestore counters or Cloud Armor in front of the HTTP endpoints).
SEC-44	Input validation	Validate every function input against a schema (types, lengths, formats); reject unknown fields.
SEC-45	Secrets rotation	Rotation schedule: Voice API key and webhook secrets every 90 days with a two-key overlap; WhatsApp system-user token on staff change; Gemini/Vertex keys replaced by service-account auth (SEC-51).
SEC-46	Web security headers	In <code>firebase.json</code> hosting: <code>Strict-Transport-Security</code> , <code>Content-Security-Policy</code> , <code>X-Frame-Options: DENY</code> , <code>X-Content-Type-Options: nosniff</code> , <code>Referrer-Policy</code> , <code>Permissions-Policy</code> . Test that Flutter web still loads.
SEC-47	Firestore & Storage rules audit	Full review of <code>firestore.rules</code> and <code>storage.rules</code> against every collection, using the rules-auditor checklist. Add emulator tests for the riskiest rules.

3.5 Data minimisation and third parties

ID	Task	Details
SEC-50	No PHI in logs	Remove names, phones, diagnoses and message bodies from <code>console.log</code> / <code>debugPrint</code> (e.g. <code>appointments.ts:451</code> , <code>:826</code>). Log IDs only. Add a lint/check in CI.

ID	Task	Details
SEC-51	Gemini → Vertex AI in India	Functions: call Vertex AI in <code>asia-south1</code> with the service account (no API key in URLs). App: <code>FirebaseAI.vertexAI(location: 'asia-south1')</code> instead of <code>googleAI()</code> . Data stays in India and isn't used for training.
SEC-52	Sarvam data settings	Recording off unless needed, shortest transcript retention, data in India, deletion on request (AI plan Q4).
SEC-53	Meta minimal data	Templates carry name, clinic, date and time only; no medical information  . Don't import WhatsApp chat history (coexistence, AI plan \$11).
SEC-54	Agreements	Data-processing agreements / terms on file for Google Cloud, Meta, Sarvam and any other processor. Keep a list of sub-processors on the website.

3.6 Audit logging and monitoring

ID	Task	Details
SEC-60	Complete patient-access audit trail	Every create/read/update/delete of patient records, files, exports and AI actions (actor = user or "AI receptionist" + call ID). Writes done by functions are logged server-side. <code>access_logs</code> rules: create-only, no update/delete.
SEC-61	Cloud Audit Logs	Turn on Data Access audit logs for Firestore, KMS, Secret Manager, Storage and IAM.
SEC-62	180-day retention in India	Route all logs to a log bucket in <code>asia-south1</code> with ≥ 180 days retention (CERT-In). Optional: archive to Cloud Storage for 1 year.
SEC-63	Alerts	Email/WhatsApp alerts for: IAM or rules changes, KMS key disable/destroy attempts, spike in failed logins, App Check rejections, <code>voiceApi</code> 5xx, unusual export volume, super-admin actions at night, budget thresholds.
SEC-64	Security Command Center	Enable the free Standard tier for misconfiguration findings; review weekly.

3.7 Backup and recovery

ID	Task	Details
SEC-70	Firestore backups	Daily scheduled backups (retain 14–30 days) + point-in-time recovery (7 days), in <code>asia-south1</code> .
SEC-71	Storage protection	Object versioning / soft delete on the medical files bucket.
SEC-72	Restore drill	Restore to a test project once per quarter. Target: lose at most 24 hours of data (RPO), back in service within 8 hours (RTO).

3.8 Secure development

ID	Task	Details
SEC-80	Dependency scanning	Dependabot (or <code>npm audit</code> + <code>dart pub outdated</code> in CI) for functions, app and super admin; fix critical issues within 7 days.
SEC-81	Secret scanning	Exists  (<code>secret_scan.yml</code>). Also enable GitHub push protection.
SEC-82	Code review rule	Every change to rules, auth, crypto or functions reviewed before deploy (<code>/code-review</code> + security review).

ID	Task	Details
SEC-83	Environments	Separate dev and production Firebase projects with separate keys; no real patient data in dev.

3.9 Privacy (DPDP) features

ID	Task	Details
SEC-90	Notice + consent	Patient notice at registration (purposes: care, reminders, AI calls); consent record stored with the patient.
SEC-91	Patient rights	Access, correction and erasure requests handled from the clinic's side (export a patient, correct, erase subject to the 3-year medical-record retention).
SEC-92	Grievance contact	Grievance officer name/email in the app and on the website; 30-day response tracking.
SEC-93	Retention	Retention rules per data type (medical records $\geq$ 3 years per NMC/DCI; call logs, WhatsApp logs, access logs per policy) with automatic deletion jobs.
SEC-94	Privacy policy & terms	Fix the dead links; publish policy covering AI receptionist, WhatsApp, sub-processors.

3.10 Incident response

ID	Task	Details
SEC-100	Incident response plan	Who decides, who fixes, who informs. Severity levels. Contact list (Google Cloud support, Meta, Sarvam, lawyer).
SEC-101	Reporting duties	CERT-In within 6 hours of noticing a reportable incident; DPDP : inform the Data Protection Board and affected patients without delay, with a detailed report to the Board within 72 hours. Templates prepared in advance.
SEC-102	Kill switches	One-step actions to: disable a compromised key, revoke all sessions for a clinic, pause WhatsApp sending, pause the AI receptionist, rotate the voice API key.
SEC-103	Tabletop drill	Practice one scenario (e.g. "a staff laptop was stolen") before VAPT.

3.11 External assurance

ID	Task	Details
SEC-110	VAPT	Engage a CERT-In empanelled auditor for apps (Android, iOS, web, Windows), APIs and cloud configuration. Fix all critical/high findings, re-test, keep the certificate. Repeat yearly and after major changes.
SEC-111	ISO 27001	See §6.

4. Phased task list

Owner: **You** = Soham, **C** = Claude (coding). Size: S $\leq$ ½ day, M $\approx$ 1 day, L $\approx$ 2–3 days.

Phase 0: before the 31 Oct launch

ID	Task	Owner	Size	Done when
SEC-34	Lock down your admin accounts (passkeys/security keys + 2FA)	You	S	All listed accounts protected

ID	Task	Owner	Size	Done when
SEC-40	Voice API hardening (AI plan V5–V11)	C	(in AI plan)	AI plan Gate 1 passed
AI-V1–V2	Reminder decryption bug fix (use SEC-11 design if KMS is ready, else temporary pepper with migration later)	C	M	Dry-run shows real names, zero foreign numbers
SEC-50	Scrub PHI from logs	C	S	Grep finds no PHI in log statements
SEC-41	Remove legacy voice endpoints once <code>voiceApi</code> is live	C	S	Not deployed
SEC-42	Remove <code>cors: true</code> from server-to-server endpoints	C	S	Done
SEC-70	Firestore daily backups + PITR	You + C	S	First backup visible
SEC-63 (part)	Budget alerts	You	S	Alerts arrive
SEC-52	Sarvam recording/retention settings	You	S	Settings recorded

Phase 1: keys and data (1–15 Nov)

ID	Task	Owner	Size	Depends on	Done when
SEC-10	KMS key ring + HSM key	You + C	S	–	Key exists, IAM limited
SEC-11	Server crypto module (KMS)	C	M	SEC-10	Unit tests pass against Dart-made values
SEC-12	<code>getClinicKey</code> callable + app switch	C	M	SEC-11	App fetches DEK via callable
SEC-13	Migration + cut-over, pepper removed	C	L	SEC-12, forced app update	No <code>wrappedKey</code> left; <code>doctor_keys</code> server-only
SEC-14	Server writes PHI encrypted	C	S	SEC-11	No plaintext PHI from functions
SEC-51	Gemini → Vertex AI <code>asia-south1</code>	C	M	–	No calls to <code>generativelanguage.googleapis.com</code>
SEC-15	Storage files review	C	S	–	Report + fixes

Phase 2: access and devices (15 Nov – 10 Dec)

ID	Task	Owner	Size	Depends on	Done when
SEC-30	Two-factor login (TOTP + SMS fallback)	C	L	Identity Platform upgrade (You)	Owners/admins can't sign in without 2FA
SEC-31	Step-up 2FA for sensitive actions	C	M	SEC-30	Export asks for 2FA
SEC-32	Sessions list + sign out everywhere	C	S	–	Works on all platforms
SEC-33	App Check monitor → enforce	C	M	SEC-21	Enforced; legit traffic 100% verified

ID	Task	Owner	Size	Depends on	Done when
SEC-21	Windows device registration / custom App Check	C	L	SEC-30	Windows passes App Check
SEC-20	Windows SQLCipher (or fallback)	C	L	–	Windows DB file unreadable without key
SEC-22	App lock (idle + biometrics/PIN/Windows Hello)	C	M	–	Locks after idle on all platforms
SEC-23	Release hardening (obfuscation, FLAG_SECURE)	C	S	–	Release build obfuscated
SEC-24	Sign-out wipe verified	C	S	–	No PHI left after sign-out
SEC-60	Full patient-access audit trail	C	L	–	Every PHI action appears in the activity log

Phase 3: monitoring, response and privacy (1–20 Dec)

ID	Task	Owner	Size	Done when
SEC-61, 62	Data Access logs + 180-day India log bucket	C	S	Retention set
SEC-63, 64	Alerts + Security Command Center	C	M	Test alerts received
SEC-35	Per-function service accounts, IAM review	C	M	No function runs as the default account
SEC-43, 44	Rate limits + input validation	C	M	Limits enforced
SEC-45	Secret rotation schedule + first rotation	You + C	S	Calendar set
SEC-46	Web security headers	C	S	securityheaders.com grade A
SEC-47	Rules audit + emulator tests	C	M	Report, all fixes deployed
SEC-71, 72	Storage versioning + restore drill	C	S	Restore tested
SEC-80–83	Dependency scanning, push protection, review rule, dev/prod split	You + C	M	In CI
SEC-90–94	Notice/consent, rights, grievance, retention, policy	C + You	L	Live in app and website
SEC-100–103	Incident plan, templates, kill switches, drill	You + C	M	Drill done
SEC-54	Agreements with processors	You	S	On file

Phase 4: VAPT (10 Dec – 15 Jan 2027)

ID	Task	Owner	Done when
SEC-110a	Choose a CERT-In empanelled auditor; agree scope (Android, iOS, web, Windows, functions, cloud config, voice + WhatsApp endpoints)	You	Contract signed
SEC-110b	Test window; fix critical/high findings; re-test	You + C	Clean re-test report

Phase 5: ISO 27001 (Jan – Jun 2027)

See §6.

5. Timeline

Oct	Phase 0: launch-critical (admin accounts, voice/WhatsApp fixes, backups)
Nov	Phase 1: KMS keys + migration, Vertex AI India → Phase 2 starts mid-Nov
Dec	Phase 2: 2FA, App Check, Windows encryption, app lock, audit trail Phase 3: logs 180d, alerts, IAM, headers, DPDP features, incident plan Phase 4: VAPT starts ~10 Dec
Jan	VAPT fixes + re-test ISO 27001 kick-off
Feb–May	ISO 27001: policies, risk assessment, controls running, internal audit
Jun	ISO 27001 certification audit (Stage 1 + Stage 2)
May 2027	DPDP main duties apply. CruDoc already compliant.

6. ISO 27001 roadmap

What it is: a certificate that CruDoc runs an **Information Security Management System (ISMS)**. That means written policies, a risk register, controls that actually operate, yearly internal audits and management review. Annex A of ISO 27001:2022 has **93 controls** in 4 themes: 37 organisational, 8 people, 14 physical, 34 technological. Most technological controls are covered by Phases 0–4 above.

Step	When	What
1. Scope	Jan	"CruDoc platform and the people who build and operate it"
2. Gap assessment	Jan	Compare against Annex A; usually with a consultant
3. Risk assessment + treatment plan	Jan–Feb	Risk register; Statement of Applicability (which controls apply and why)
4. Policies	Feb	Information security policy, access control, cryptography & key management, acceptable use, secure development, supplier security, incident management, business continuity, backup, logging & monitoring, data retention, remote work, asset management
5. Run the controls	Feb–Apr	Collect evidence for 2–3 months: access reviews, backups tested, training done, vendor reviews, incidents logged
6. Training	Mar	Security awareness for everyone with access, plus phishing basics
7. Internal audit + management review	Apr–May	Independent internal audit; fix findings
8. Certification audit	Jun	Stage 1 (documents) + Stage 2 (evidence) by an accredited certification body
9. Keep it	Yearly	Surveillance audits; recertification every 3 years

Cost (rough, year 1): consultant ₹2–5 lakh, certification body ₹1.5–3 lakh, total about **₹3–8 lakh**; then about ₹1–2 lakh a year for surveillance audits. Compliance-automation tools (e.g. Sprinto, Vanta) can replace part of the consultant cost; compare quotes.

7. Costs

Item	Cost	Notes
Cloud KMS HSM key + operations	A few hundred ₹/month	One key; per-operation fees tiny at this scale
Identity Platform (for 2FA)	Free at this scale for TOTP; SMS fallback charged per message	Phone OTP login already pays SMS
App Check	Free tiers cover current volume (Play Integrity, App Attest, reCAPTCHA Enterprise)	Check reCAPTCHA Enterprise volume for web
Firestore backups + PITR	Small (storage-based)	
Log retention 180 days	Small (₹ hundreds/month)	
Vertex AI instead of Gemini API	About the same per token	
VAPT (CERT-In empanelled)	₹50,000 – 2,00,000 per round	Yearly
ISO 27001	₹3–8 lakh year 1, ₹1–2 lakh/year after	
Hardware security keys for admins	~₹2,500–4,000 each	2 per admin (one spare)
Development effort	~25–30 working days (Claude)	Phases 0–3

8. Decisions and open questions

#	Question	Recommendation	Owner
D1	Server can read patient data (under audit) vs full end-to-end encryption	Server-readable via KMS. E2E would rule out reminders and the AI receptionist.	You
D2	2FA mandatory for whom?	Mandatory for owners/admins, on by default for everyone	You
D3	voice-receptionist/ Python service	Decommission once Sarvam's agent is live, else include in VAPT	You
D4	Windows: SQLCipher vs fallback (field encryption + BitLocker policy)	Try SQLCipher first (1-day spike)	C
D5	Cloud HSM region	asia-south1 if available, else asia-south2	C
D6	ISO 27001 with consultant vs automation tool	Get 2–3 quotes in December	You
Q1	Does Sarvam support request signing or IP allowlisting for tool calls and webhooks?	Ask Sarvam	You
Q2	Does Firebase MFA work in the Windows build?	Spike in SEC-30	C

Appendix A: what a clinic will see

Change	When	What the doctor notices
Two-factor login	Phase 2	Sets up an authenticator app once; enters a 6-digit code at sign-in on a new device
App lock	Phase 2	App asks for fingerprint / Windows Hello after 5 minutes idle

Change	When	What the doctor notices
Device list	Phase 2	"Signed-in devices" in settings with "sign out everywhere"
Activity log	Phase 2	Complete list of who opened, changed or exported each patient
Patient notice	Phase 3	One-line notice on the patient form; consent saved
Security page	After VAPT	"Tested by a CERT-In empanelled auditor"; later "ISO 27001 certified"

Appendix B: glossary

Word	Meaning
KMS / HSM	Google's key vault / the tamper-resistant hardware inside it that holds keys
DEK / KEK	Data key that encrypts patient fields / key that encrypts (wraps) the data key
Envelope encryption	Data encrypted with a DEK; the DEK encrypted with a KEK in the vault
MFA / 2FA / TOTP	Two-factor login / the 6-digit code from an authenticator app
App Check	Proof that a request comes from a genuine CruDoc app, not a script
VAPT	Vulnerability Assessment and Penetration Testing: hired, legal hacking
CERT-In empanelled	Auditor approved by India's national cyber-security agency
ISMS	Information Security Management System: the processes ISO 27001 certifies
RPO / RTO	How much data you can afford to lose / how fast you must be back online
PITR	Point-in-time recovery: restore the database to any minute in the last 7 days
PHI	Personal health information: anything identifying a patient and their care